

**UNIVERSIDAD NACIONAL FEDERICO VILLARREAL
FACULTAD DE INGENIERÍA INDUSTRIAL Y DE SISTEMAS
ESCUELA PROFESIONAL DE INGENIERÍA DE SISTEMAS**



INFORME DE INGENIERIA SOCIAL

OBJETIVO

Desarrollo con SET

AUTOR

Quispe Mescua George Angel

CURSO

Ciberseguridad

2026

1. Objetivo

El presente informe detalla la ejecución de una práctica de ingeniería social mediante la herramienta Social Engineer Toolkit (SET), con el principal objetivo de lograr comprender el funcionamiento de un ataque de tipo Credential Harvester que proporciona la herramienta. El desarrollo de la actividad se llevó a cabo de forma local dentro de un entorno de laboratorio, sin involucrar a terceros. El objetivo académico es identificar las técnicas empleadas por un atacante para suplantar un sitio legítimo y capturar credenciales.

1.1 Alcance

- El laboratorio se ejecutó exclusivamente en mi máquina local, empleando la dirección 127.0.0.1:80
- No se empleó ninguna dirección IP externa, dominio real ni infraestructura de terceros
- Las credenciales empleadas fueron datos de prueba ficticios, sin relación con cuentas reales
- El sitio clonado corresponde a una plantilla predefinida del propio SET

2. Social Engineer Toolkit (SET)

SET es un framework de código abierto, desarrollado por TrustedSec y orientado a pruebas de penetración centradas en el factor humano. Incluye módulos para ataques de phishing dirigido (spear phishing), vectores de ataque web, generación de medios infecciosos, creación de payloads, entre otros. Para esta práctica se utilizó el módulo de Website Attack Vectors, específicamente el método Credential Harvester Attack.

3. Herramientas y Entorno de Trabajo

Sistema operativo	Kali Linux
Herramienta principal	Social Engineer Toolkit (SET) version 8.0.3
Plantilla clonada	Google
Dirección IP de pruebas	127.0.0.1:80
Navegador	Mozilla Firefox
Tipo de ataque simulado	Phishing mediante clonación de formulario de inicio de sesión

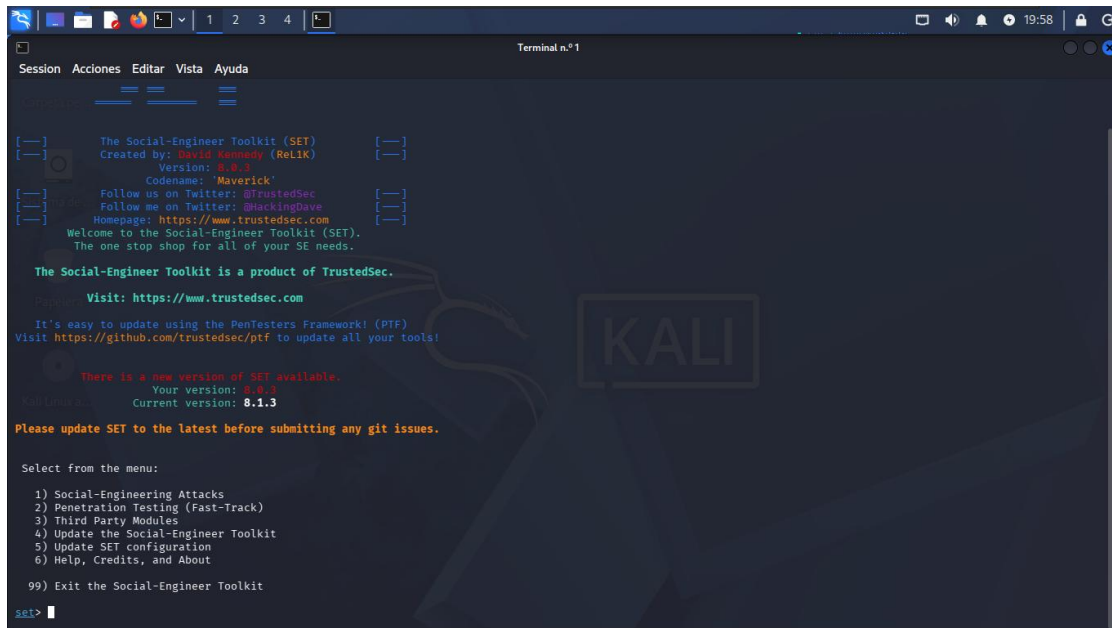
4. Metodología y Desarrollo de la Práctica

Se procede a describir el procedimiento realizado, acompañado de las capturas de pantalla obtenidas durante la ejecución del laboratorio.

4.1 Inicio de SET

Se inició la herramienta SET desde la terminal de Kali Linux. El menú principal mostró las seis categorías disponibles: ataques de ingeniería social, pruebas de penetración rápida, módulos de terceros,

actualización de la herramienta, actualización de configuración, y ayuda. Se selecciono la primera opción correspondiente a Social Engineering Attacks.



```
Session Acciones Editar Vista Ayuda

[---] The Social-Engineer Toolkit (SET) [---]
[---] Created by: David Kennedy (ReL1K) [---]
[---] Version: 8.0.3 [---]
[---] Codename: 'Maverick' [---]
[---] Follow us on Twitter: @TrustedSec [---]
[---] Follow me on Twitter: @hackingdave [---]
[---] Homepage: https://www.trustedsec.com [---]
Welcome to the Social-Engineer Toolkit (SET).
The one stop shop for all of your SE needs.

The Social-Engineer Toolkit is a product of TrustedSec.
Visit: https://www.trustedsec.com

It's easy to update using the PenTesters Framework! (PTF)
Visit https://github.com/trustedsec/ptf to update all your tools!

There is a new version of SET available.
Your version: 8.0.3
Current version: 8.1.3

Please update SET to the latest before submitting any git issues.

Select from the menu:

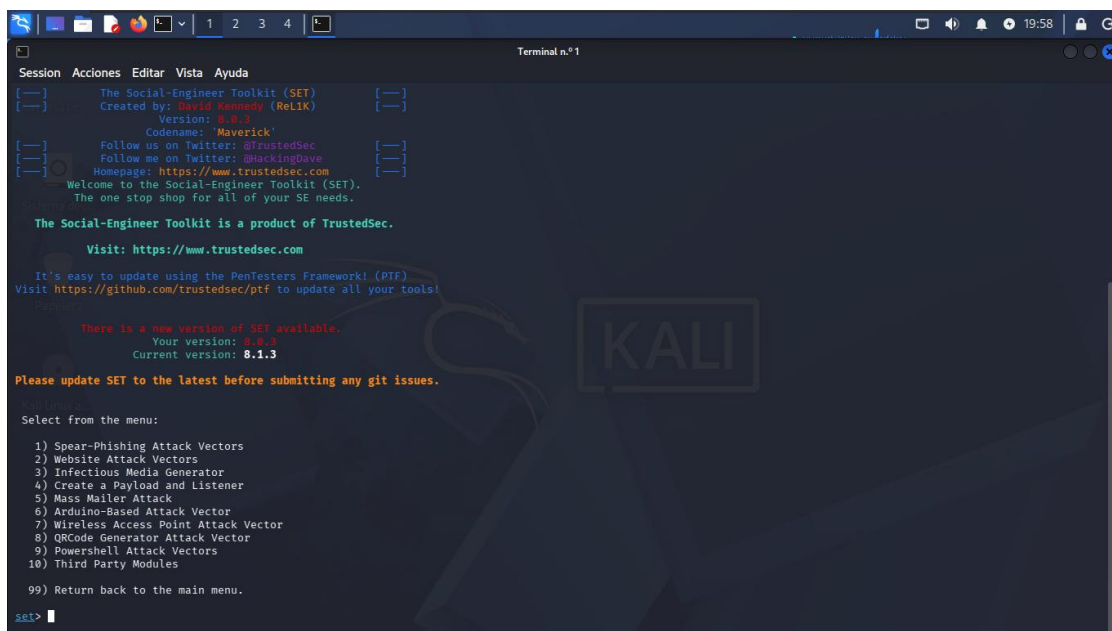
1) Social-Engineering Attacks
2) Penetration Testing (Fast-Track)
3) Third Party Modules
4) Update the Social-Engineer Toolkit
5) Update SET configuration
6) Help, Credits, and About

99) Exit the Social-Engineer Toolkit

set>
```

4.2 Selección del vector de ataque web

Dentro del submenu de ataques de ingeniería social se eligió la opción Website Attack Vectors, la cual despliega los distintos métodos disponibles para comprometer a un usuario a través de un sitio web siendo estos: Java Applet Attack, Metasploit Browser Exploit, Credential Harvester, Tabnabbing, Web Jacking, Multi Attack y HTA Attack.



```
Session Acciones Editar Vista Ayuda

[---] The Social-Engineer Toolkit (SET) [---]
[---] Created by: David Kennedy (ReL1K) [---]
[---] Version: 8.0.3 [---]
[---] Codename: 'Maverick' [---]
[---] Follow us on Twitter: @TrustedSec [---]
[---] Follow me on Twitter: @hackingdave [---]
[---] Homepage: https://www.trustedsec.com [---]
Welcome to the Social-Engineer Toolkit (SET).
The one stop shop for all of your SE needs.

The Social-Engineer Toolkit is a product of TrustedSec.
Visit: https://www.trustedsec.com

It's easy to update using the PenTesters Framework! (PTF)
Visit https://github.com/trustedsec/ptf to update all your tools!

There is a new version of SET available.
Your version: 8.0.3
Current version: 8.1.3

Please update SET to the latest before submitting any git issues.

Select from the menu:

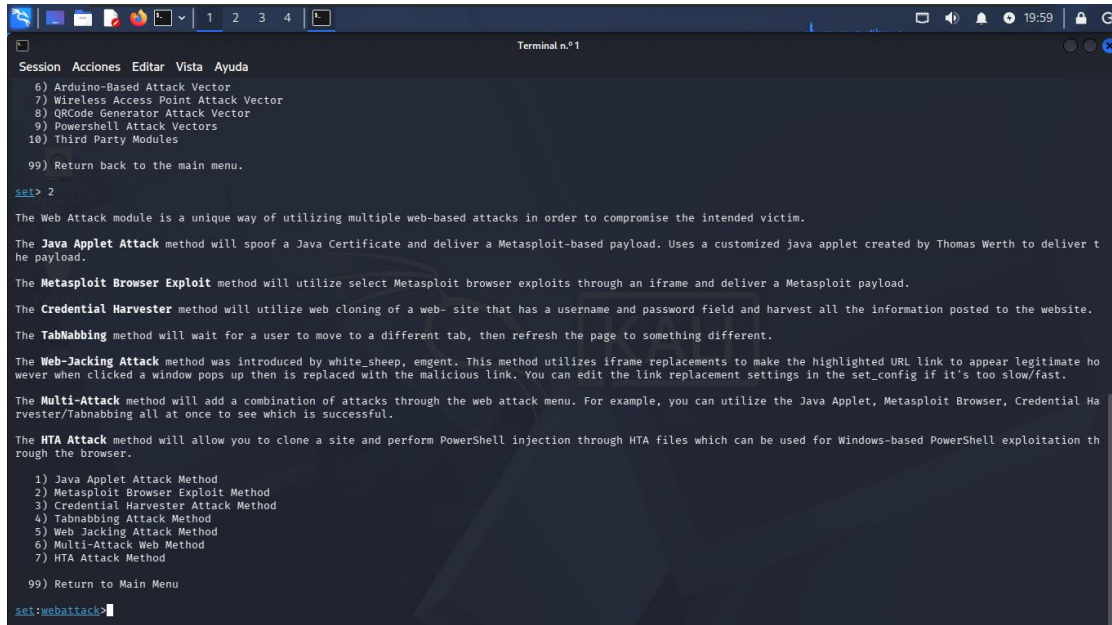
1) Spear-Phishing Attack Vectors
2) Website Attack Vectors
3) Infectious Media Generator
4) Create a Payload and Listener
5) Mass Mailer Attack
6) Arduino-Based Attack Vector
7) Wireless Access Point Attack Vector
8) QRCode Generator Attack Vector
9) Powershell Attack Vectors
10) Third Party Modules

99) Return back to the main menu.

set>
```

4.3 Selección del método Credential Harvester

Se seleccionó el método Credential Harvester Attack Method, el cual permite clonar un sitio web y capturar cualquier información enviada a través de los campos que corresponden a sus formularios. SET describe que esta técnica funciona reescribiendo los campos de un formulario clonado para registrar lo que el usuario ingrese.



```
Session Acciones Editar Vista Ayuda
6) Arduino-Based Attack Vector
7) Wireless Access Point Attack Vector
8) QRCode Generator Attack Vector
9) Powershell Attack Vectors
10) Third Party Modules
99) Return back to the main menu.

set> 2

The Web Attack module is a unique way of utilizing multiple web-based attacks in order to compromise the intended victim.

The Java Applet Attack method will spoof a Java Certificate and deliver a Metasploit-based payload. Uses a customized java applet created by Thomas Werth to deliver the payload.

The Metasploit Browser Exploit method will utilize select Metasploit browser exploits through an iframe and deliver a Metasploit payload.

The Credential Harvester method will utilize web cloning of a web-site that has a username and password field and harvest all the information posted to the website.

The TabNabbing method will wait for a user to move to a different tab, then refresh the page to something different.

The Web-Jacking Attack method was introduced by white_sheep, emgent. This method utilizes iframe replacements to make the highlighted URL link to appear legitimate however when clicked a window pops up then is replaced with the malicious link. You can edit the link replacement settings in the set_config if it's too slow/fast.

The Multi-Attack method will add a combination of attacks through the web attack menu. For example, you can utilize the Java Applet, Metasploit Browser, Credential Harvester/Tabnabbing all at once to see which is successful.

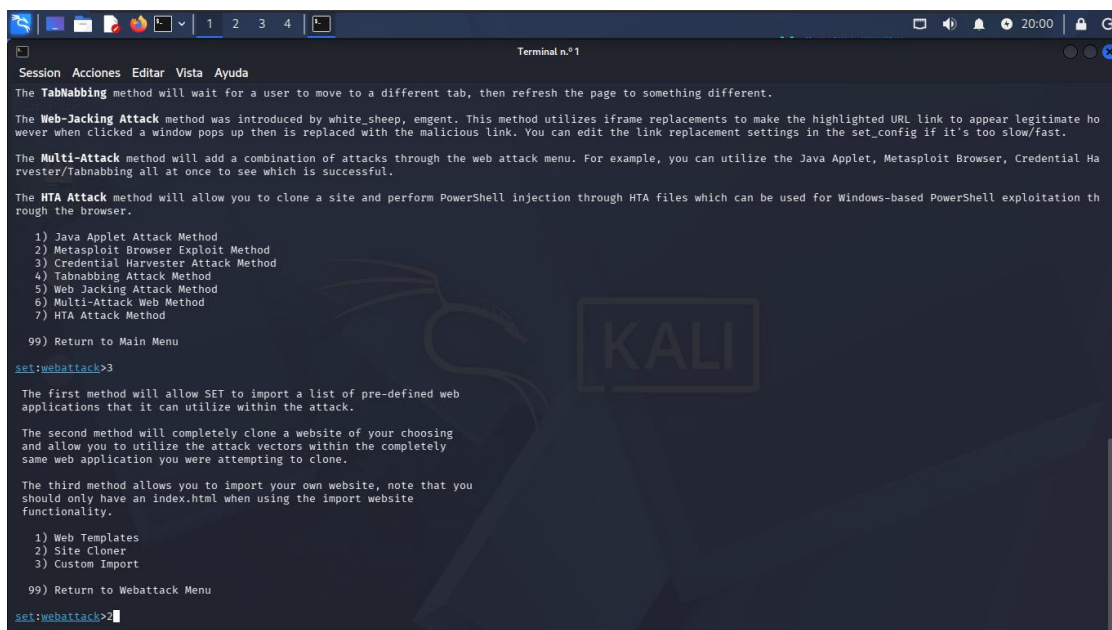
The HTA Attack method will allow you to clone a site and perform PowerShell injection through HTA files which can be used for Windows-based PowerShell exploitation through the browser.

1) Java Applet Attack Method
2) Metasploit Browser Exploit Method
3) Credential Harvester Attack Method
4) Tabnabbing Attack Method
5) Web Jacking Attack Method
6) Multi-Attack Web Method
7) HTA Attack Method
99) Return to Main Menu

set:webattack>
```

4.4 Elección del modo de clonación

SET ofrece tres formas de obtener el sitio a clonar: importar una lista de aplicaciones predefinidas (Web Templates), clonar un sitio específico ingresando su dirección (Site Cloner), o importar un sitio propio (Custom Import). Para esta práctica se utilizó la opción Web Templates, que incluye plantillas ya preparadas por la herramienta.



```
The TabNabbing method will wait for a user to move to a different tab, then refresh the page to something different.

The Web-Jacking Attack method was introduced by white_sheep, emgent. This method utilizes iframe replacements to make the highlighted URL link to appear legitimate however when clicked a window pops up then is replaced with the malicious link. You can edit the link replacement settings in the set_config if it's too slow/fast.

The Multi-Attack method will add a combination of attacks through the web attack menu. For example, you can utilize the Java Applet, Metasploit Browser, Credential Harvester/Tabnabbing all at once to see which is successful.

The HTA Attack method will allow you to clone a site and perform PowerShell injection through HTA files which can be used for Windows-based PowerShell exploitation through the browser.

1) Java Applet Attack Method
2) Metasploit Browser Exploit Method
3) Credential Harvester Attack Method
4) Tabnabbing Attack Method
5) Web Jacking Attack Method
6) Multi-Attack Web Method
7) HTA Attack Method
99) Return to Main Menu

set:webattack>3

The first method will allow SET to import a list of pre-defined web applications that it can utilize within the attack.

The second method will completely clone a website of your choosing and allow you to utilize the attack vectors within the completely same web application you were attempting to clone.

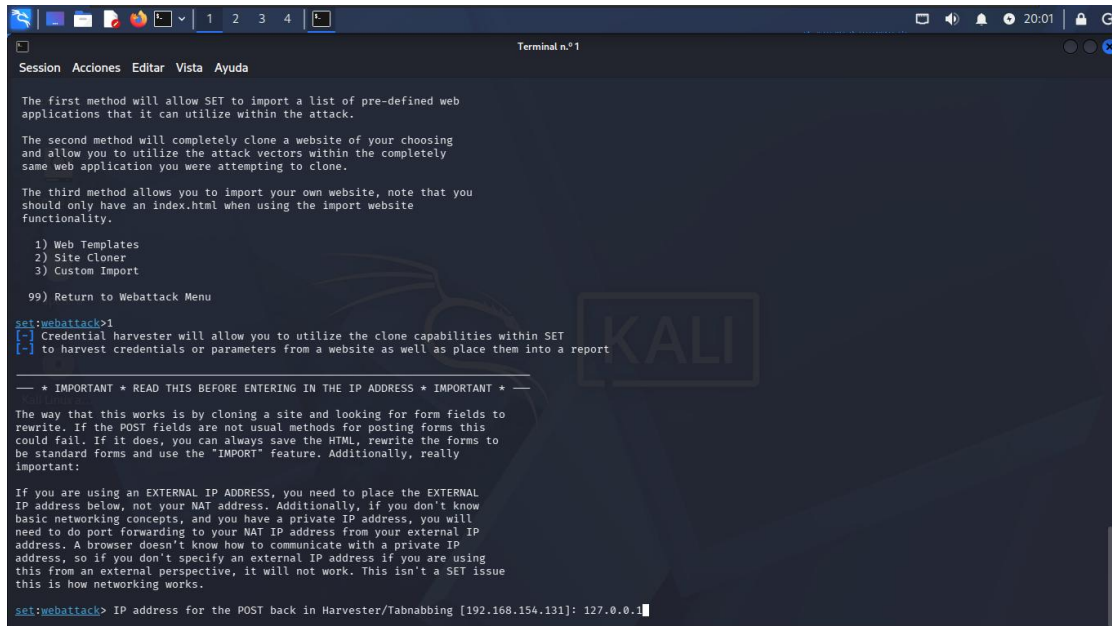
The third method allows you to import your own website, note that you should only have an index.html when using the import website functionality.

1) Web Templates
2) Site Cloner
3) Custom Import
99) Return to Webattack Menu

set:webattack>
```

4.5 Configuración de la dirección de retorno

SET solicita la dirección IP donde se recibirán los datos capturados. Esta dirección debe ser la del equipo que ejecuta el ataque como indica el programa. Dado que la práctica se realizó de forma local, se configuro la dirección 127.0.0.1



```
Session Acciones Editar Vista Ayuda

The first method will allow SET to import a list of pre-defined web
applications that it can utilize within the attack.

The second method will completely clone a website of your choosing
and allow you to utilize the attack vectors within the completely
same web application you were attempting to clone.

The third method allows you to import your own website, note that you
should only have an index.html when using the import website
functionality.

1) Web Templates
2) Site Cloner
3) Custom Import
99) Return to Webattack Menu

set:webattack>1
[*] Credential harvester will allow you to utilize the clone capabilities within SET
[*] to harvest credentials or parameters from a website as well as place them into a report

--- * IMPORTANT * READ THIS BEFORE ENTERING IN THE IP ADDRESS * IMPORTANT * ---

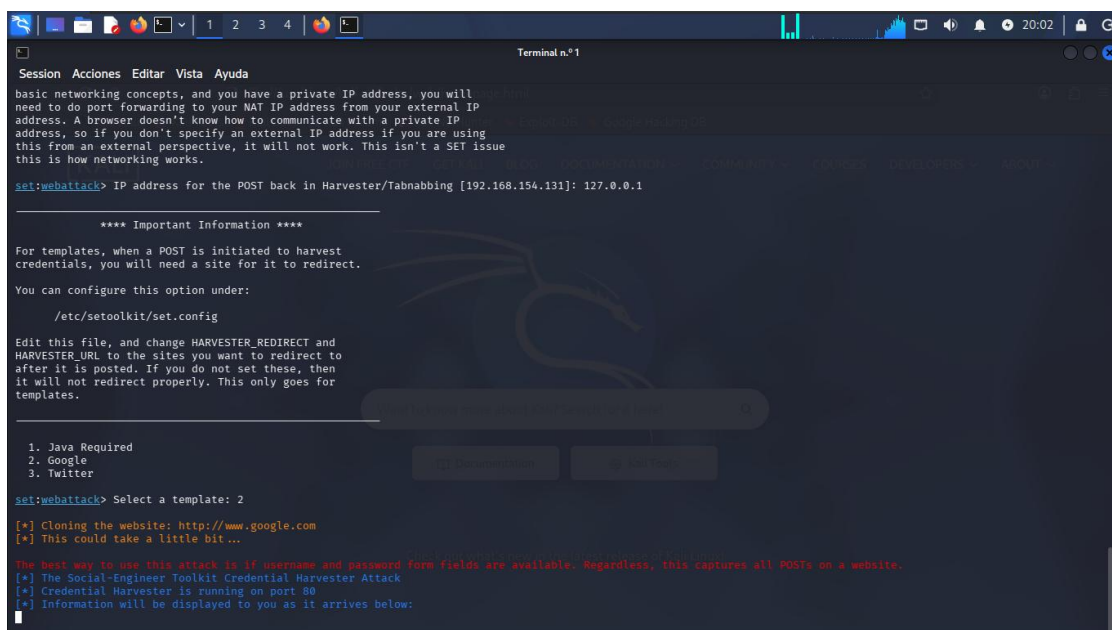
The way that this works is by cloning a site and looking for form fields to
rewrite. If the POST fields are not usual methods for posting forms this
could fail. If it does, you can always save the HTML, rewrite the forms to
be standard forms and use the "IMPORT" feature. Additionally, really
important:

If you are using an EXTERNAL IP ADDRESS, you need to place the EXTERNAL
IP address below, not your NAT address. Additionally, if you don't know
basic networking concepts, and you have a private IP address, you will
need to do port forwarding to your NAT IP address from your external IP
address. A browser doesn't know how to communicate with a private IP
address, so if you don't specify an external IP address if you are using
this from an external perspective, it will not work. This isn't a SET issue
this is how networking works.

set:webattack> IP address for the POST back in Harvester/Tabnabbing [192.168.154.131]: 127.0.0.1
```

4.6 Selección de la plantilla y levantamiento del servicio

Entre las plantillas disponibles (Java Required, Google y Twitter) se selecciono la plantilla Google. SET procedió a clonar la apariencia del sitio e inicio automáticamente un servidor web local en el puerto 80 para alojar la pagina falsa y registrar cualquier credencial ingresada.



```
Session Acciones Editar Vista Ayuda

basic networking concepts, and you have a private IP address, you will
need to do port forwarding to your NAT IP address from your external IP
address. A browser doesn't know how to communicate with a private IP
address, so if you don't specify an external IP address if you are using
this from an external perspective, it will not work. This isn't a SET issue
this is how networking works.

set:webattack> IP address for the POST back in Harvester/Tabnabbing [192.168.154.131]: 127.0.0.1

**** Important Information ****

For templates, when a POST is initiated to harvest
credentials, you will need a site for it to redirect.
You can configure this option under:

/etc/settoolkit/set.config

Edit this file, and change HARVESTER_REDIRECT and
HARVESTER_URL to the sites you want to redirect to
after it is posted. If you do not set these, then
it will not redirect properly. This only goes for
templates.

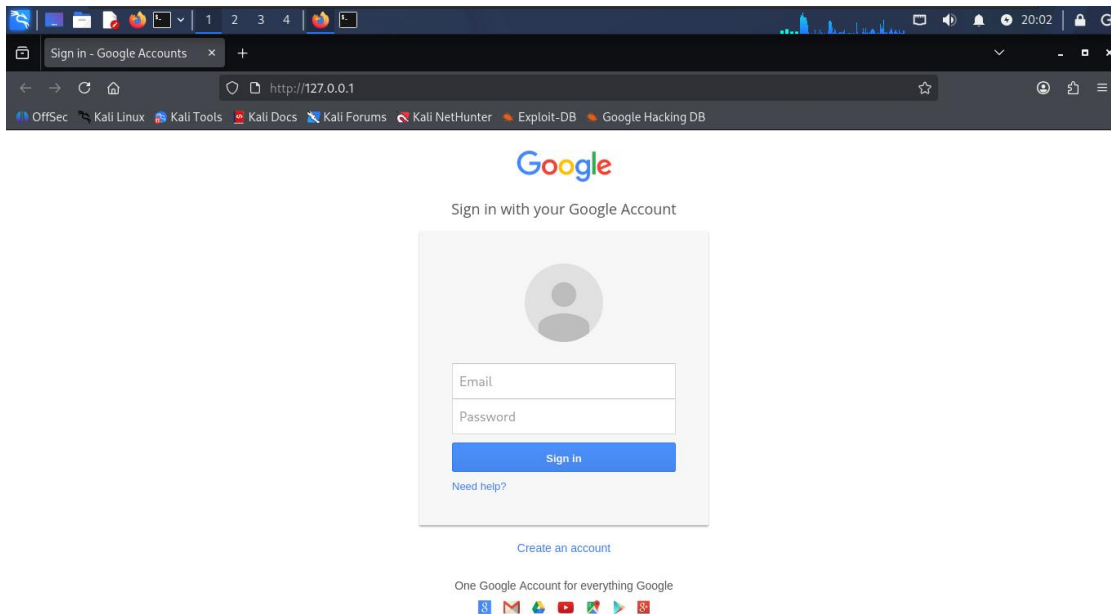
1. Java Required
2. Google
3. Twitter
99) Return to Webattack Menu

set:webattack> Select a template: 2
[*] Cloning the website: http://www.google.com
[*] This could take a little bit ...

The best way to use this attack is if username and password form fields are available. Regardless, this captures all POSTs on a website.
[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
```

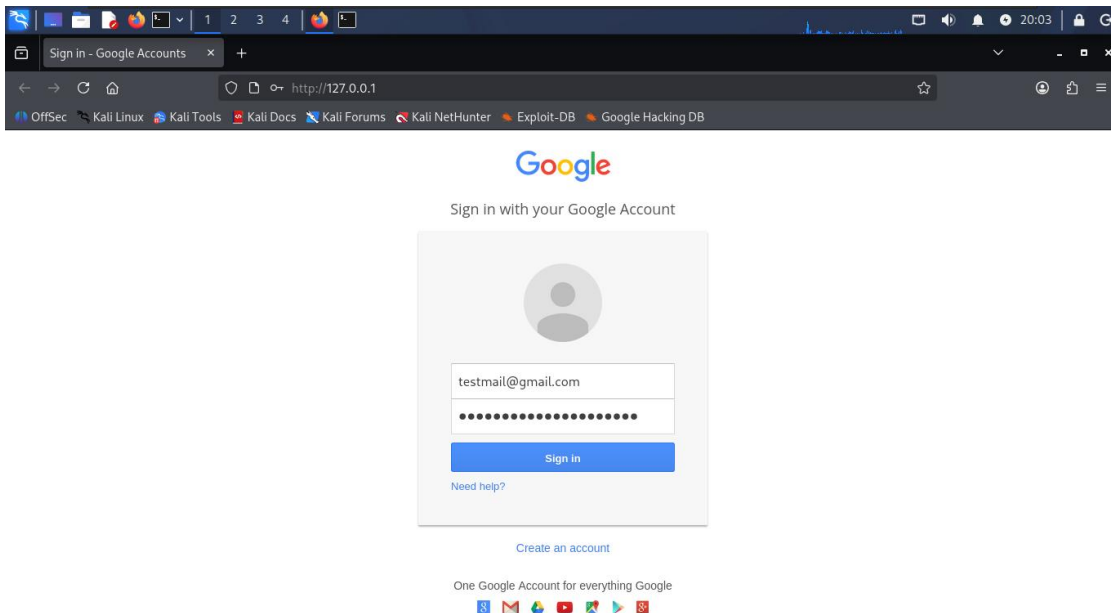
4.7 Visualización del sitio clonado

Al acceder desde el navegador a la dirección 127.0.0.1:80, se mostró una replica visual del formulario de inicio de sesión de Google, generada localmente por SET.



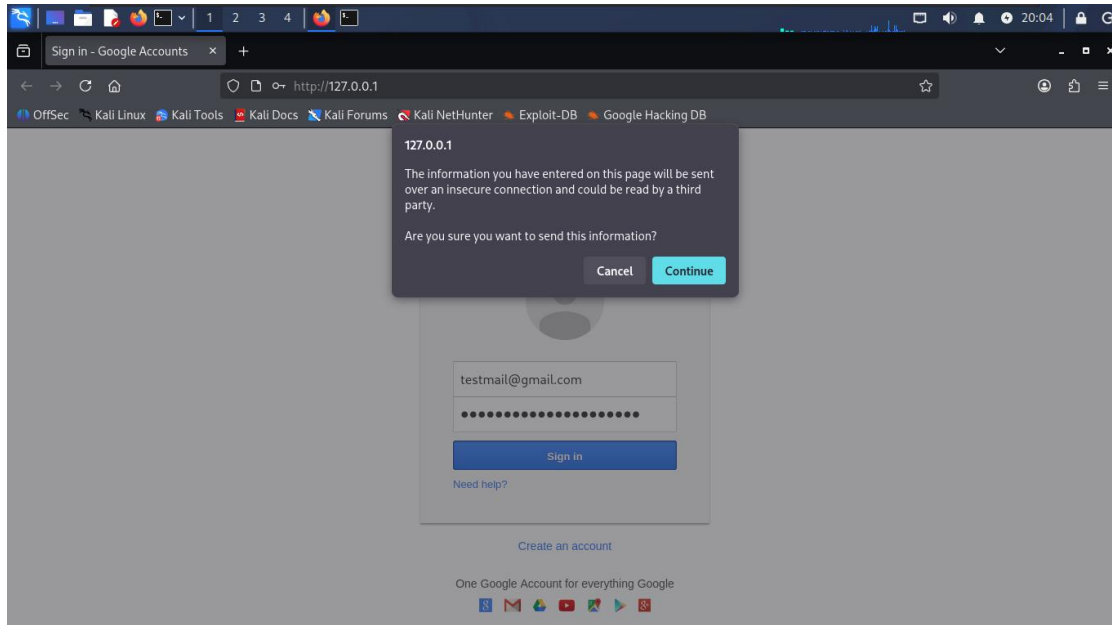
4.8 Ingreso de datos de prueba

Con fines exclusivamente demostrativos se ingresaron un correo y una contraseña ficticios, para observar el comportamiento del formulario clonado frente al envío de datos.



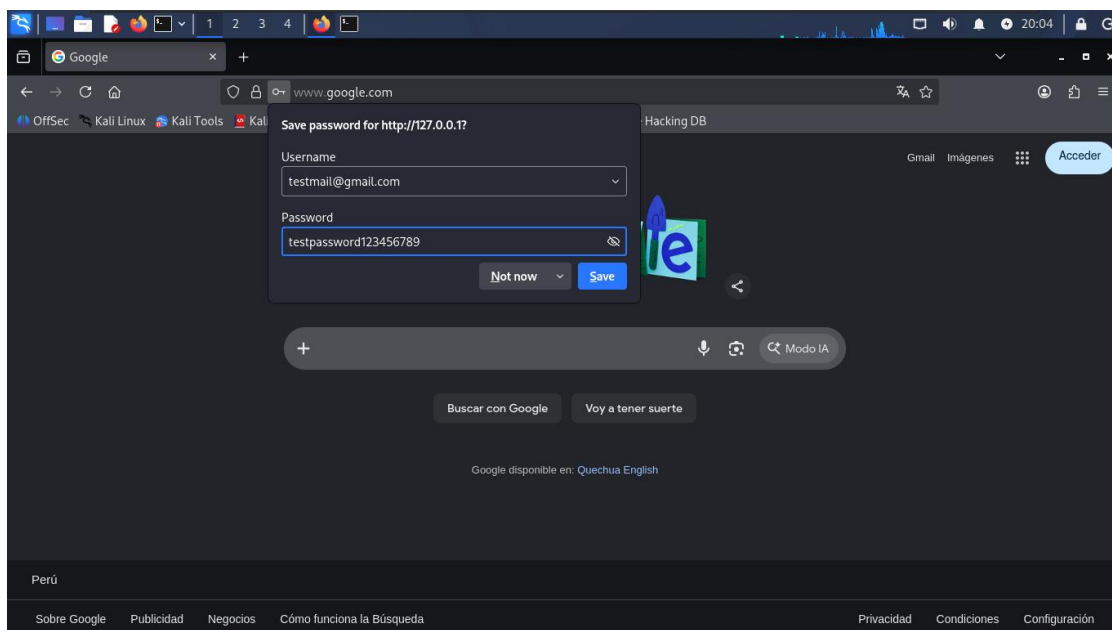
4.9 Advertencia del navegador

Al enviar el formulario, Firefox mostró una advertencia de seguridad indicando que la información se enviaría por una conexión insegura. Esta alerta corresponde a un mecanismo nativo de protección del navegador y refuerza la importancia de verificar el cifrado y el certificado de un sitio antes de introducir datos sensibles.



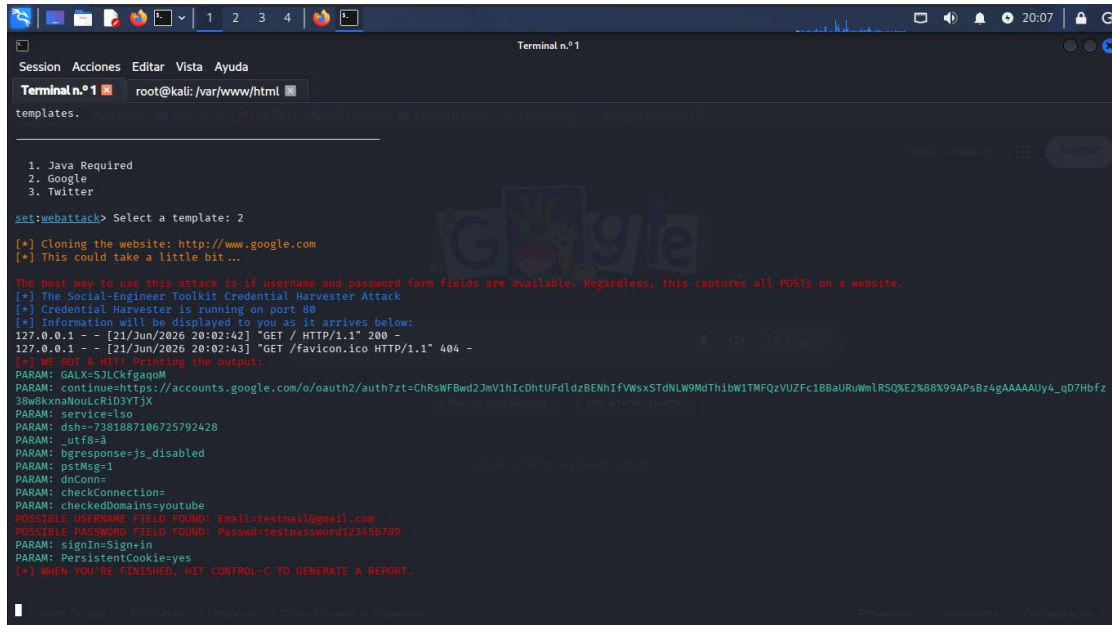
4.10 Redirección tras el envío

Una vez confirmado el envío, el formulario clonado redirigió al usuario hacia el sitio real de Google, simulando un flujo normal de autenticación. El propio navegador, al detectar el formulario de inicio de sesión del sitio real, ofreció guardar la contraseña de prueba, lo que ilustra como una víctima real podría no notar ninguna diferencia durante el ataque.



4.11 Captura de credenciales en la terminal

En la terminal donde se ejecuto SET se observo el aviso WE GOT A HIT, seguido del listado de parámetros enviados por el formulario. Entre ellos se identificaron claramente los campos correspondientes al correo y a la contraseña de prueba ingresados previamente, confirmando que la herramienta capturo exitosamente la información ingresada por el usuario.



```
Session Acciones Editar Vista Ayuda
Terminal n.º1 root@kali: /var/www/html
templates.

1. Java Required
2. Google
3. Twitter

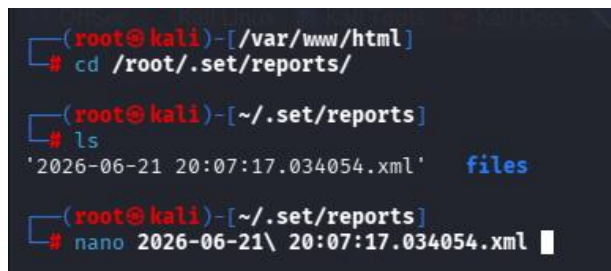
set:webattack> Select a template: 2

[*] Cloning the website: http://www.google.com
[*] This could take a little bit ...

The best way to use this attack is if username and password form fields are available. Regardless, this captures all POSTs on a website.
[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
127.0.0.1 - - [21/Jun/2026 20:02:42] "GET / HTTP/1.1" 200 -
127.0.0.1 - - [21/Jun/2026 20:02:43] "GET /favicon.ico HTTP/1.1" 404 -
[*] WE GOT A HIT! Printing the output:
PARAM: GALX=SJLckfgaqoM
PARAM: continue=https://accounts.google.com/o/oauth2/auth?zt=ChRsWFBwd2JmV1h1cDhtUfdldzBENhIFVwxsSTdNLW9mdTh1bW1TMfQzVUZFc1B8aURuWm1RSQKE2%88%99APsBz4gAAAAUy4_qD7Hbfz
30w8kxnaNoulcR1D3YtjX
PARAM: service=iso
PARAM: dsh=7381887106725792428
PARAM: _utf8=a
PARAM: bgresponse=js_disabled
PARAM: pstMsg=1
PARAM: dnConn=
PARAM: checkedDomains=youtube
PARAM: checkedDomains=youtube
POSSIBLE USERNAME FIELD FOUND: Email=testmail@gmail.com
POSSIBLE PASSWORD FIELD FOUND: Passwd=testpassword123456789
PARAM: signIn=Sign-in
PARAM: PersistentCookie=yes
[*] WHEN YOU'RE FINISHED, HIT CONTROL-C TO GENERATE A REPORT.
```

4.12 Generación del reporte

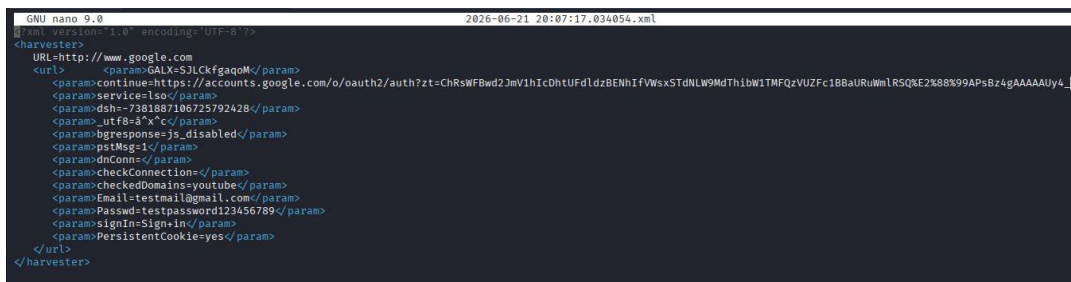
Al finalizar la captura, SET genero automáticamente un archivo de reporte en formato XML dentro de la carpeta de reportes de la herramienta. Dicho archivo almacena de forma estructurada todos los parámetros recibidos durante la sesión del ataque, incluyendo el correo y la contraseña de prueba.



```
(root@kali)-[/var/www/html]
# cd /root/.set/reports/

(root@kali)-[~/set/reports]
# ls
'2026-06-21 20:07:17.034054.xml' files

(root@kali)-[~/set/reports]
# nano 2026-06-21\ 20:07:17.034054.xml
```



```
GNU nano 9.0 2026-06-21 20:07:17.034054.xml
#?xml version='1.0' encoding='UTF-8'?>
<harvester>
  <url>http://www.google.com
    <param>GALX=SJLckfgaqoM</param>
    <param>continue=https://accounts.google.com/o/oauth2/auth?zt=ChRsWFBwd2JmV1h1cDhtUfdldzBENhIFVwxsSTdNLW9mdTh1bW1TMfQzVUZFc1B8aURuWm1RSQKE2%88%99APsBz4gAAAAUy4_qD7Hbfz30w8kxnaNoulcR1D3YtjX</param>
    <param>service=iso</param>
    <param>dsh=7381887106725792428</param>
    <param>_utf8=a</param>
    <param>bgresponse=js_disabled</param>
    <param>pstMsg=1</param>
    <param>dnConn=</param>
    <param>checkedDomains=youtube</param>
    <param>checkedDomains=youtube</param>
    <param>Email=testmail@gmail.com</param>
    <param>Passwd=testpassword123456789</param>
    <param>signIn=Sign-in</param>
    <param>PersistentCookie=yes</param>
  </url>
</harvester>
```


5. Resultados

La practica permitió comprobar de manera controlada el funcionamiento completo de un ataque de Credential Harvester:

1. SET clono exitosamente la interfaz visual de un sitio de autenticación conocido, sin requerir conocimientos avanzados de desarrollo web
2. El formulario clonado capturo los datos ingresados antes de redirigir al usuario hacia el sitio legitimo, dificultando que la victima note el engaño
3. El navegador emitió advertencias de seguridad relacionadas con la conexión insegura, las cuales actúan como una primera línea de defensa si el usuario las lee con atención
4. Toda la información capturada quedo registrada localmente en un archivo de reporte, lo cual en un escenario real equivaldría a información en poder del atacante

6. Conclusiones

- La ingeniería social, y en particular el phishing mediante clonación de sitios, sigue siendo un vector de ataque altamente efectivo porque explota la confianza del usuario y no una vulnerabilidad técnica del sistema
- Herramientas como SET demuestran que la creación de un sitio falso convincente requiere poco esfuerzo técnico, lo que resalta la importancia de la concientización del usuario final como principal barrera de defensa
- Las advertencias del navegador sobre conexiones inseguras o certificados inválidos son señales clave que deben ser tomadas en cuenta antes de ingresar credenciales en cualquier formulario